

ĐỀ TÀI NHÓM ĐỀ XUẤT: QUẢN LÝ VÀ KIỂM SOÁT TRUY CẬP TÀI LIỆU AN TOÀN TRÊN CSDL ĐÁM MÂY TRONG DOANH NGHIỆP

1.1. Giới thiệu đề tài

Trong bối cảnh các doanh nghiệp ngày càng chuyển dịch sang hạ tầng điện toán đám mây, việc lưu trữ và chia sẻ tài liệu nội bộ trên môi trường cloud trở nên phổ biến hơn bao giờ hết. Tuy nhiên, điều này cũng đặt ra những thách thức lớn về **an toàn thông tin** và **kiểm soát truy cập dữ liệu**, đặc biệt là với các tài liệu quan trọng, nhạy cảm liên quan đến hoạt động quản trị, tài chính, nhân sự hay nghiên cứu.

Đề tài “**Quản lý và Kiểm soát Truy cập Tài liệu An toàn trên CSDL Đám mây trong Doanh nghiệp**” được xây dựng nhằm giải quyết vấn đề trên thông qua một hệ thống quản lý tài liệu tích hợp các cơ chế bảo mật hiện đại. Hệ thống không chỉ hỗ trợ **tạo, lưu trữ, chia sẻ và quản lý phiên bản tài liệu** mà còn cung cấp **các cơ chế kiểm soát truy cập dựa trên thuộc tính (ABAC)** và **mã hóa dữ liệu bằng CP-ABE kết hợp AES-GCM**, đảm bảo rằng chỉ những người dùng có thuộc tính phù hợp mới có quyền truy cập vào dữ liệu.

Ngoài ra, hệ thống còn cho phép **quản lý người dùng, khóa mã hóa, chính sách truy cập và quyền hạn của Super Admin**, đồng thời cung cấp **các báo cáo thống kê toàn hệ thống** để phục vụ công tác giám sát và audit.

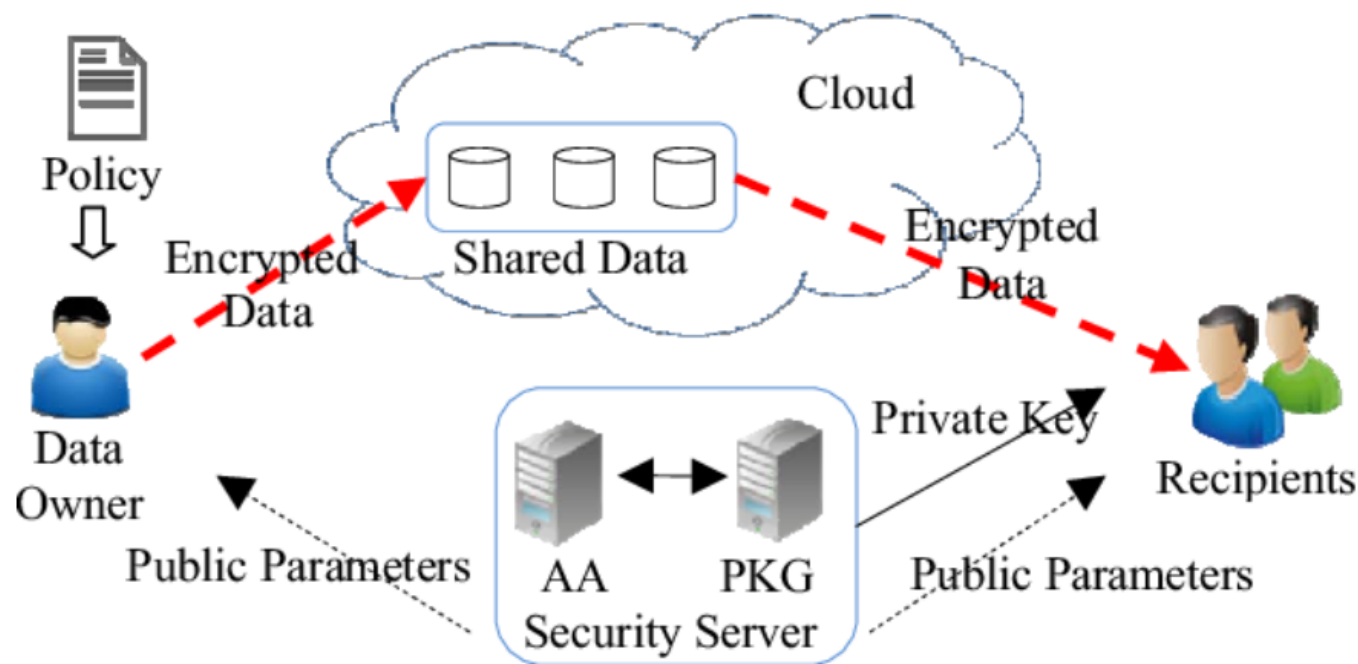
Mục tiêu chính của đề tài là:

- Đảm bảo **an toàn, bảo mật và toàn vẹn** của tài liệu lưu trữ trên nền tảng đám mây.
- Tạo cơ chế kiểm soát truy cập **linh hoạt và chi tiết**, phù hợp với từng đối tượng người dùng và từng loại tài nguyên.
- Hỗ trợ doanh nghiệp **giảm thiểu rủi ro rò rỉ thông tin**, đồng thời **tối ưu hóa quy trình quản lý và chia sẻ tài liệu** trong nội bộ.

Các bên liên quan trong hệ thống

- **CA (Certificate Authority):** Là thành phần chịu trách nhiệm cấp phát, quản lý và xác thực chứng chỉ/khoá mã hóa. CA đóng vai trò trung tâm tin cậy, đảm bảo rằng các khoá truy cập và chứng chỉ số trong hệ thống là hợp lệ, không bị giả mạo.
- **Data Owner (Chủ sở hữu dữ liệu):** Là người tạo ra và quản lý tài liệu. Data Owner chịu trách nhiệm **mã hoá và upload file, gán chính sách truy cập, quản lý phiên bản** và quyết định ai được quyền truy cập vào dữ liệu của mình. Họ cũng có quyền thay đổi hoặc thu hồi quyền truy cập đối với tài liệu.
- **Data User (Người dùng dữ liệu):** Là những người trong doanh nghiệp được cấp quyền để truy cập tài liệu theo các **chính sách ABAC** đã được thiết lập. Data User chỉ có thể xem hoặc thao tác trên dữ liệu nếu thuộc tính của họ thỏa mãn điều kiện truy cập mà Data Owner định nghĩa.

Qua đó, đề tài hướng đến việc xây dựng một giải pháp **quản lý dữ liệu an toàn, tin cậy và phù hợp** cho các doanh nghiệp đang chuyển dịch sang môi trường làm việc số trên nền tảng điện toán đám mây.



1.2. Danh sách các yêu cầu

STT	Tên yêu cầu	Biểu mẫu	Qui định	Ghi chú
1	Tạo người dùng	BM1	QĐ1	
2	Upload file mã hóa	BM2	QĐ2	
3	Quản lý danh sách file	BM3		
4	Quản lý thuộc tính người dùng	BM4	QĐ4	
5	Quản lý khóa truy cập	BM5	QĐ5	
6	Quản lý phiên bản file	BM6	QĐ6	
7	Quản lý chính sách truy cập	BM7	QĐ7	
8	Quản lý Super Admin	BM8	QĐ8	
9	Quản lý lược đồ thuộc tính	BM9	QĐ9	
10	Lập báo cáo hệ thống	BM10.1, BM10.2		
11	Thay đổi cấu hình hệ thống		QĐ11	

1.3. Danh sách các biểu mẫu và qui định

1.3.1. Biểu mẫu 1 và qui định 1

BM1: Thông Tin Người Dùng

Họ và tên: _____
Email: _____
Username: _____
Mật khẩu: _____

Loại người dùng: _____

Ngày đăng ký: _____

QĐ1: Có 2 loại người dùng (normal, super_admin). Chỉ có Super Admin mới tạo được người dùng trong doanh nghiệp. Người dùng không được tự phép đăng ký mới tài khoản.

Ví dụ: Thông tin người dùng

BM1: Thông Tin Người Dùng

Họ và tên: Nguyễn Văn A

Email: itmanager001@company.com

Username: 22520001

Mật khẩu: *****

Loại người dùng: normal

Ngày đăng ký: 08/09/2025

1.3.2 Biểu mẫu 2 và qui định 2

BM2: Thông Tin File Upload

Tên file: _____

Loại file: _____

Kích thước: _____

Chính sách truy cập: _____

Mô tả: _____

Tags: _____

Ngày upload: _____

Người upload: _____

QĐ2: Có 5 loại file chính (text/plain, document, image, video, audio). Kích thước tối đa 100MB. Chỉ nhận file không chứa virus và được mã hóa dựa trên thuộc tính chính sách bản mã (CP-ABE). Chính sách thuộc tính được quy định bởi chủ sở hữu (Data Owner) của file đó, người sử dụng (Data User) có thuộc tính phù hợp với chính sách thì sẽ truy cập được file. Không ai có thể thay đổi được Chính sách truy cập của file ngoài chủ sở hữu.

Ví dụ: Thông tin file upload

BM2: Thông Tin File Upload

Tên file: bao-cao-quy-1.pdf

Loại file: document

Kích thước: 39 bytes

Chính sách truy cập: "department:it" OR "department:hr"

Mô tả: File báo cáo quý 1 của doanh nghiệp.

Tags: report, upload

Ngày upload: 08/09/2025

Người upload: 22520001

1.3.3 Biểu mẫu 3

BM3: Danh Sách File

STT	Mã File	Tên File	Loại File	Người Sở Hữu	Trạng Thái
1	0ae91604-eff2-46cd-81f0-e714b5936ea3	bao-cau-quy-1.pdf	document	22520001	ACTIVE
2	1f2cb81c-5a08-459a-9bac-2122896a8aaa	version.txt	text/plain	22520001	HISTORICAL

1.3.4 Biểu mẫu 4 và qui định 4

BM4: Phiếu Quản Lý Thuộc Tính Người Dùng

User ID: _____
Người cập nhật: _____
Ngày cập nhật: _____
Trạng thái: _____

STT	Thuộc Tính	Giá Trị	Trạng Thái
1			
2			

QĐ4: Chỉ Super Admin mới có quyền phân quyền và thay đổi thuộc tính người dùng. Mỗi người dùng có một document trong collection user_attributes chứa các thuộc tính của họ trong doanh nghiệp: department, clearance_level, role, location, data_access, employment_status. Thuộc tính được sử dụng để kiểm soát truy cập file và tài nguyên.

Ví dụ:

BM4: Phiếu Quản Lý Thuộc Tính Người Dùng
User ID: 22520001
Người cập nhật: 21520001 (Super Admin)
Ngày cập nhật: 08/09/2025
Trạng thái: active

STT	Thuộc Tính	Giá Trị	Trạng Thái
1	clearance_level	secret	active
2	department	hr	active
3	role	intern	active
4	data_access	super_admin	active

1.3.5 Biểu mẫu 5 và qui định 5

BM5: Phiếu Quản Lý Khóa Truy Cập

User ID: _____
Loại khóa: _____
Thuật toán: _____

Ngày tạo: _____

Trạng thái: _____

STT	Key ID	Phiên Bản	Thuộc Tính	Trạng Thái
1				
2				

QĐ5: Khóa truy cập được tạo cho mỗi người dùng dựa trên thuộc tính của họ và được mã hoá với thuật toán AES-256-GCM (khoá AES được dẫn xuất từ mật khẩu người dùng). Khóa có thời hạn phụ thuộc vào thuộc tính của người dùng (nếu người dùng được thay đổi thuộc tính thì khoá cũng được tạo mới và mã hoá lại).

Ví dụ:

BM5: Phiếu Quản Lý Khóa Mã Hóa
User ID: 22520001
Loại khóa: user_private_key
Thuật toán: AES-256-GCM
Ngày tạo: 08/09/2025
Trạng thái: active

STT	Key ID	Phiên Bản	Thuộc Tính	Trạng Thái
1	privkey_22520001_1757298029	1	['clearance_level:secret', 'department:hr']	active

1.3.6 Biểu mẫu 6 và qui định 6

BM6: Phiếu Phiên Bản File

File ID: _____
Phiên bản: _____
Kích thước: _____
Người tạo: _____
Ngày tạo: _____
Mô tả thay đổi: _____

QĐ6: Mỗi file có thể có nhiều phiên bản. Chỉ có phiên bản ACTIVE mới có thể được tải xuống. Các phiên bản HISTORICAL được lưu trữ để audit.

Ví dụ:

BM6: Phiếu Phiên Bản File
File ID: 0ae91604-eff2-46cd-81f0-e714b5936ea3
Phiên bản: 1.0.0
Kích thước: 39 bytes
Người tạo: 22520001
Ngày tạo: 08/09/2025
Mô tả thay đổi: Initial version

1.3.7 Biểu mẫu 7 và qui định 7

BM7: Phiếu Chính Sách Truy Cập ABAC

Policy ID: _____
Tên chính sách: _____
Mô tả: _____
Tài nguyên: _____
Hành động: _____
Điều kiện: _____
Hiệu lực: _____
Độ ưu tiên: _____
Trạng thái: _____
Ngày tạo: _____

QĐ7: Mỗi chính sách ABAC định nghĩa quy tắc truy cập dựa trên thuộc tính của người dùng, tài nguyên và môi trường. Chỉ Super Admin mới có thể tạo/sửa chính sách. Có 2 loại hiệu lực: ALLOW và DENY. Độ ưu tiên cao hơn sẽ được áp dụng trước.

Ví dụ:

BM7: Phiếu Chính Sách Truy Cập ABAC
Policy ID: executives_all_access
Tên chính sách: Executive All Access
Mô tả: Executive level access to all resources
Tài nguyên: shared_files
Hành động: read, write, delete
Điều kiện: user.role == "executive"
Hiệu lực: ALLOW
Độ ưu tiên: 100
Trạng thái: active
Ngày tạo: 08/09/2025

1.3.8 Biểu mẫu 8 và qui định 8**BM8: Thông Tin Super Admin**

ID: _____
Username: _____
Email: _____
Quyền hạn: _____
Vai trò: _____
Trạng thái: _____
Lần đăng nhập cuối: _____
Ngày tạo: _____

QĐ8: Super Admin có quyền cao nhất trong hệ thống. Có thể quản lý tất cả người dùng, file, chính sách và cấu hình hệ thống.

Ví dụ:

BM8: Thông Tin Super Admin
ID: 21520001
Username: SuperAdmin

Email: admin@company.com
Quyền hạn: ['user_management', 'file_management', 'system_config', 'policy_management']
Vai trò: super_admin
Trạng thái: active
Lần đăng nhập cuối: 08/09/2025
Ngày tạo: 08/09/2025

1.3.9 Biểu mẫu 9 và qui định 9

BM9: Lược Đồ Thuộc Tính Khả Dụng

Schema ID: _____
Phiên bản: _____
Ngày cập nhật: _____
Người cập nhật: _____

STT	Tên Thuộc Tính	Loại	Giá Trị Có Thể	Bắt Buộc
1				
2				

QĐ9: Lược đồ thuộc tính khả dụng định nghĩa các thuộc tính hợp lệ cho người dùng trong hệ thống. Chỉ Super Admin mới có thể thay đổi schema. Mỗi thay đổi được lưu versioning.

Ví dụ:

BM9: Lược Đồ Thuộc Tính Hệ Thống
Schema ID: user_attribute_schemas
Phiên bản: 1.0
Ngày cập nhật: 08/09/2025
Người cập nhật: 21520001

STT	Tên Thuộc Tính	Loại	Giá Trị Có Thể	Bắt Buộc
1	clearance_level	enum	[public, confidential, secret, top_secret]	Có
2	department	enum	[hr, finance, it, operations, executive]	Có
3	role	enum	[intern, employee, manager, director, ceo]	Có
4	location	string	Any valid location	Không
5	data_access	enum	[basic, advanced, super_admin]	Có
6	employment_status	enum	[active, inactive, terminated]	Có

1.3.2.10 Biểu mẫu 10

Biểu mẫu 10.1

BM10.1: Báo Cáo Thống Kê Collections Database

Ngày: _____

STT	Tên Collection	Số Documents	Ví Dụ Document ID
1	users	2	21520001, 22520001
2	shared_files	2	0ae91604-eff2-46cd-81f0-e714b5936ea3
3	file_versions	3	26173b83-09b7-4914-bc04-9e70376298ce
4	user_attributes	1	UA22520001
5	user_private_keys	4	privkey_22520001_1757298029
6	access_policies	30	SuperAdmin_Full_Access
7	super_admin	1	21520001
8	system_schemas	1	user_attribute_schemas

Tổng số collections: 8
Tổng số documents: 44

Biểu mẫu 10.2

BM10.2: Báo Cáo Thống Kê Loại Người Dùng

Ngày: _____

STT	Loại User	Số Lượng	Tỉ Lệ
1	super_admin	1	50%
2	regular	1	50%

Tổng số người dùng: 2

1.3.11 Qui định 11

QĐ11: Super Admin có thể thay đổi các qui định như sau:

- **QĐ1:** Thay đổi về loại người dùng (regular, super_admin), thời hạn tài khoản, quyền hạn cơ bản.
- **QĐ2:** Thay đổi loại file được hỗ trợ, kích thước file tối đa.
- **QĐ4:** Thay đổi các thuộc tính phân quyền: department, clearance_level, role, location, data_access, employment_status.
- **QĐ5:** Thay đổi chính sách versioning file (ACTIVE, HISTORICAL), số lượng phiên bản tối đa được lưu trữ.
- **QĐ6:** Thay đổi các chính sách ABAC: thêm/sửa/xóa chính sách, thay đổi độ ưu tiên, điều kiện truy cập.
- **QĐ7:** Quản lý tài khoản Super Admin: tạo/vô hiệu hóa tài khoản, thay đổi quyền hạn, reset password.
- **QĐ8:** Cập nhật lược đồ thuộc tính: thêm/sửa/xóa thuộc tính, thay đổi loại dữ liệu, giá trị hợp lệ.